

**SIMULASI PENERAPAN SISTEM MANAJEMEN
KEAMANAN INFORMASI (SMKI) BERDASARKAN ISO/IEC
27001 PADA PT. KARYA SEHAT ABADI (RUMAH SAKIT)**



Oleh :

1. 221011401507 Arizal Almuttaqin

**PROGRAM STUDI TEKNIK INFORMATIKA
FAKULTAS ILMU KOMPUTER
UNIVERSITAS PAMULANG
2024/2025**

Daftar isi

Daftar isi	i
BAB I.....	2
PENDAHULUAN	2
1.1. Latar Belakang.....	2
1.2. Ruang Lingkup SMKI.....	2
1.3. Profil Organisasi PT. Karya Sehat Abadi	2
a. Jenis Bisnis.....	2
b. Struktur Organisasi Singkat	2
c. Layanan Utama	2
d. Data atau Aset Informasi Penting	2
BAB II.....	3
ANALISIS KONTEKS ORGANISASI.....	3
2.1. Identifikasi Isu Internal dan Eksternal	3
2.2. Identifikasi Pihak Berkepentingan dan Kebutuhan Mereka.....	5
Kesimpulan Analisis Konteks:.....	6
BAB III	7
PENILAIAN RISIKO KEAMANAN INFORMASI.....	7
3.1. Metodologi Penilaian Risiko.....	7
3.3. Kesimpulan Penilaian Risiko	10
BAB IV	11
PEMILIHAN DAN RANCANGAN KONTROL KEAMANAN INFORMASI	11
4.1. Daftar Kontrol Keamanan yang Dipilih.....	11
BAB V	13
RANCANGAN DOKUMEN UTAMA SMKI	13
5.1. Kebijakan Keamanan Informasi (Information Security Policy)	13
5.2. Tujuan Keamanan Informasi (Information Security Objectives).....	13
BAB VI.....	15
KESIMPULAN DAN REKOMENDASI	15
6.1. Kesimpulan	15
6.2. Rekomendasi.....	15
KESIMPULAN (BAB I – VI)	16
DAFTAR PUSTAKA	18

BAB I

PENDAHULUAN

1.1. Latar Belakang

Dalam era digitalisasi yang semakin pesat, informasi telah menjadi aset yang sangat kritis bagi hampir semua organisasi, tidak terkecuali di industri kesehatan. Rumah sakit, sebagai penyedia layanan kesehatan, mengelola data yang sangat sensitif dan bersifat rahasia, mulai dari rekam medis pasien, data finansial, hingga hasil penelitian. Kebocoran, kehilangan, atau kerusakan terhadap data-data ini tidak hanya dapat mengakibatkan kerugian finansial dan reputasi, tetapi juga dapat membahayakan keselamatan pasien dan melanggar regulasi seperti Undang-Undang Nomor 27 Tahun 2022 tentang Perlindungan Data Pribadi (PDP).

Oleh karena itu, diperlukan suatu kerangka kerja yang sistematis dan komprehensif untuk mengelola dan melindungi aset informasi tersebut. ISO/IEC 27001 merupakan standar internasional yang menyediakan kerangka kerja untuk menetapkan, menerapkan, mengoperasikan, memantau, meninjau, memelihara, dan meningkatkan Sistem Manajemen Keamanan Informasi (SMKI). Makalah ini akan mensimulasikan penerapan ISO/IEC 27001 di sebuah organisasi rumah sakit fiktif, yaitu PT. Karya Sehat Abadi, untuk menggambarkan langkah-langkah dan manfaat yang dapat diperoleh.

1.2. Ruang Lingkup SMKI

Dalam simulasi ini, ruang lingkup penerapan SMKI ISO/IEC 27001 akan mencakup **seluruh organisasi PT. Karya Sehat Abadi**. Hal ini didasarkan pada pertimbangan bahwa aset informasi kritis tersebar di berbagai departemen dan proses bisnis inti rumah sakit, mulai dari pendaftaran pasien, pelayanan medis, farmasi, keuangan, hingga sumber daya manusia. Dengan ruang lingkup yang menyeluruh, diharapkan dapat tercipta budaya keamanan informasi yang merata dan terintegrasi di semua lini organisasi.

1.3. Profil Organisasi PT. Karya Sehat Abadi

a. Jenis Bisnis

PT. Karya Sehat Abadi adalah sebuah rumah sakit swasta tipe B yang berlokasi di sebuah kota metropolitan. Rumah sakit ini menyediakan layanan kesehatan paripurna (komprehensif) yang meliputi pelayanan rawat jalan, rawat inap, gawat darurat, dan pelayanan penunjang medis lainnya. Seiring dengan perkembangannya, rumah sakit ini telah mengadopsi Sistem Informasi Rumah Sakit (Hospital Information System - HIS) untuk mendigitalisasi sebagian besar proses bisnisnya.

b. Struktur Organisasi Singkat

Struktur organisasi PT. Karya Sehat Abadi dipimpin oleh seorang Direktur Utama. Di bawahnya, terdapat beberapa direksi yang membidangi:

- **Direktur Medik dan Keperawatan:** Bertanggung jawab atas semua layanan medis dan keperawatan.
- **Direktur Keuangan dan Umum:** Mengelola aspek keuangan, sumber daya manusia, dan logistik.
- **Direktur Layanan dan Teknologi Informasi:** Membawahi divisi Teknologi Informasi (TI) serta layanan non-medis seperti customer service.

Unit-unit kerja utama meliputi: Instalasi Gawat Darurat (IGD), Poliklinik, Rawat Inap, Farmasi, Laboratorium, Radiologi, Bagian Keuangan, Bagian SDM, dan **Divisi Teknologi Informasi** yang menjadi tulang punggung operasional sistem digital.

c. Layanan Utama

Layanan utama yang disediakan oleh PT. Karya Sehat Abadi antara lain:

1. **Layanan Rawat Jalan:** Konsultasi dokter spesialis, pemeriksaan penunjang.
2. **Layanan Rawat Inap:** Perawatan dengan berbagai kelas kamar.
3. **Layanan Gawat Darurat (IGD):** Penanganan medis darurat 24 jam.
4. **Layanan Penunjang Medis:** Pemeriksaan Laboratorium, Radiologi (X-Ray, CT-Scan, MRI), dan Fisioterapi.
5. **Layanan Farmasi:** Pengelolaan dan pendistribusian obat-obatan.
6. **Layanan Pemeriksaan Kesehatan (Medical Check-Up):** Untuk perorangan dan perusahaan.

d. Data atau Aset Informasi Penting

Aset informasi merupakan komponen kunci yang perlu dilindungi. Berikut adalah aset informasi penting di PT. Karya Sehat Abadi:

1. **Data Rekam Medis Elektronik:** Berisi riwayat kesehatan, diagnosis, hasil lab, resep obat, dan catatan perkembangan pasien. Aset ini sangat sensitif, rahasia, dan memengaruhi keselamatan pasien secara langsung.
2. **Data Pribadi Pasien dan Karyawan:** Meliputi NIK, alamat, nomor telepon, dan informasi kontak lainnya. Perlindungannya diatur dalam UU PDP.
3. **Data Finansial:** Data pembayaran pasien, klaim asuransi, laporan keuangan, dan data rekening bank.
4. **Data Penelitian dan Kekayaan Intelektual:** Hasil penelitian klinis dan protokol pengobatan tertentu.

5. **Infrastruktur TI:** Server yang menhosting database HIS, aplikasi, dan jaringan komputer. Gangguan pada infrastruktur ini dapat melumpuhkan operasional rumah sakit.
6. **Perangkat Keras Medis yang Terhubung Jaringan:** Seperti alat CT-Scan dan MRI yang terintegrasi dengan sistem untuk mengirimkan hasil pemeriksaan. Kerentanan pada perangkat ini dapat mengganggu layanan.

Dengan profil dan kompleksitas aset informasi yang dimiliki, penerapan SMKI berbasis ISO/IEC 27001 menjadi sebuah kebutuhan mendesak bagi PT. Karya Sehat Abadi untuk memastikan keberlangsungan layanan, mematuhi regulasi, dan yang terpenting, menjaga kepercayaan pasien dan masyarakat.

BAB II

ANALISIS KONTEKS ORGANISASI

Sebelum menerapkan SMKI, organisasi harus memahami konteks di mana ia beroperasi. Analisis konteks ini bertujuan untuk mengidentifikasi faktor internal dan eksternal yang dapat mempengaruhi kemampuan organisasi dalam mencapai tujuan SMKI, serta memahami kebutuhan dan ekspektasi pihak-pihak berkepentingan.

2.1. Identifikasi Isu Internal dan Eksternal

Berdasarkan analisis terhadap lingkungan operasional PT. Karya Sehat Abadi, berikut adalah isu-isu internal dan eksternal yang relevan dengan keamanan informasi.

Tabel 2.1. Identifikasi Isu Internal dan Eksternal

Kategori	Isu	Dampak terhadap Keamanan Informasi
Internal	1. Budaya Keamanan Informasi yang Masih Lemah	Karyawan mungkin tidak mengikuti prosedur keamanan (misalnya, berbagi password, menggunakan USB tanpa scanning), menjadi titik lemah utama terhadap serangan phishing atau social engineering.
	2. Keterbatasan Anggaran dan Sumber Daya TI	Investasi untuk teknologi keamanan mutakhir (seperti Advanced Threat Protection, SIEM) terhambat. Tim TI mungkin kekurangan personel yang khusus menangani keamanan siber (security analyst).

Kategori	Isu	Dampak terhadap Keamanan Informasi
Eksternal	3. Tingginya Ketergantungan pada Sistem HIS yang Usianya Sudah Tua (Legacy System)	Sistem legacy seringkali memiliki celah keamanan (vulnerabilities) yang tidak lagi ditambah (unpatched) oleh vendor, membuatnya rentan terhadap eksploitasi.
	4. Kurangnya Kebijakan dan Prosedur Keamanan yang Terdokumentasi dan Disosialisasikan	Ketidakkonsistenan dalam penanganan informasi, ketidaktahuan tanggung jawab, dan ketiadaan dasar hukum untuk mengambil tindakan disiplin.
	5. Kompleksitas Jaringan karena Integrasi Banyak Perangkat Medis	Setiap perangkat medis yang terhubung (IoT) merupakan titik masuk (entry point) potensial baru bagi penyerang jika tidak dikonfigurasi dan dipisahkan dengan aman.
	1. Ancaman Siber yang Semakin Maju dan Sering (Ransomware, Phishing, Data Breach)	Risiko tinggi terhadap gangguan operasional (ransomware mengunci data) dan kebocoran data sensitif pasien, yang berujung pada denda dan kerugian reputasi.
	2. Peningkatan Regulasi Perlindungan Data Pribadi (UU PDP)	Menciptakan kewajiban hukum untuk melindungi data pribadi pasien. Kegagalan mematuhi dapat mengakibatkan sanksi administratif, pidana, dan gugatan perdata.
	3. Tuntutan dan Ekspektasi Pasien akan Kerahasiaan Data Kesehatannya	Kepercayaan pasien adalah aset utama. Kebocoran data akan menyebabkan hilangnya kepercayaan dan berpindahnya pasien ke rumah sakit lain.
	4. Ketergantungan pada Pihak Ketiga (Vendor HIS, Cloud Services, Asuransi)	Risiko keamanan dari rantai pasok. Jika vendor mengalami insiden, data RS bisa ikut terbuka. Perlu perjanjian kerahasiaan dan audit keamanan yang ketat.
	5. Persaingan Bisnis di Industri Kesehatan	Pesaing mungkin melakukan corporate espionage untuk mencuri data penelitian atau strategi bisnis.

2.2. Identifikasi Pihak Berkepentingan dan Kebutuhan Mereka

Pihak berkepentingan (stakeholder) adalah individu atau kelompok yang dapat mempengaruhi, dipengaruhi, atau memiliki kepentingan terhadap keberhasilan SMKI PT. Karya Sehat Abadi. Kebutuhan mereka terhadap keamanan informasi harus dipahami dan dipertimbangkan.

Tabel 2.2. Identifikasi Pihak Berkepentingan dan Kebutuhan Keamanan Informasi

Pihak Berkepentingan	Kebutuhan dan Ekspektasi terhadap Keamanan Informasi
Pasien	- Kerahasiaan dan privasi data kesehatan pribadi mereka terjamin. - Data rekam medis akurat, lengkap, dan hanya dapat diakses oleh tenaga medis yang berwenang. - Layanan kesehatan tidak terganggu oleh insiden siber (seperti ransomware).
Tenaga Medis & Kesehatan (Dokter, Perawat, Apteker)	- Akses yang lancar dan andal ke sistem rekam medis untuk memberikan perawatan yang tepat dan cepat. - Integritas data pasien (tidak ada yang diubah atau hilang) untuk menghindari kesalahan diagnosis. - Autentikasi yang mudah namun aman untuk mengakses sistem.
Direksi & Manajemen	- Kepatuhan terhadap semua regulasi yang berlaku (UU PDP, Standar Akreditasi). - Perlindungan terhadap aset informasi untuk mendukung kelangsungan bisnis dan reputasi. - Laporan manajemen yang akurat tentang status dan efektivitas keamanan informasi.
Karyawan (Non-Medis)	- Kejelasan peran dan tanggung jawab dalam menjaga keamanan informasi. - Pelatihan yang memadai untuk mengidentifikasi dan melaporkan ancaman keamanan.

Pihak Berkepentingan

Kebutuhan dan Ekspektasi terhadap Keamanan Informasi

- Prosedur kerja yang aman dan tidak menghambat produktivitas.

Regulator & Badan Akreditasi (Kemenkes, Komisi Akreditasi RS)

- Kepatuhan rumah sakit terhadap standar pelayanan dan regulasi privasi data.
- Adanya bukti terdokumentasi tentang penerapan manajemen keamanan informasi.

Mitra Bisnis & Pihak Ketiga (Perusahaan Asuransi, Vendor)

- Pertukaran data yang aman dan terenkripsi.
- Adanya NDA dan kontrak yang mengatur tanggung jawab keamanan informasi.
- Akses yang diberikan kepada mereka terbatas dan terkendali.

Masyarakat Umum

- Keyakinan bahwa rumah sakit dapat dipercaya untuk menjaga data sensitif mereka.
- Transparansi dalam hal penanganan insiden jika terjadi kebocoran data.

Kesimpulan Analisis Konteks:

Berdasarkan analisis di atas, dapat disimpulkan bahwa PT. Karya Sehat Abadi beroperasi dalam lingkungan yang penuh dengan tantangan keamanan informasi, baik dari dalam maupun luar. Tekanan dari regulasi, ancaman siber, dan tuntutan pasien mengharuskan rumah sakit untuk membangun SMKI yang robust. Analisis konteks ini akan menjadi dasar fundamental untuk menetapkan kebijakan keamanan informasi, menentukan tujuan, dan merancang kontrol yang efektif pada bab-bab selanjutnya.

BAB III

PENILAIAN RISIKO KEAMANAN INFORMASI

Penilaian risiko merupakan inti dari penerapan SMKI ISO/IEC 27001. Tahap ini bertujuan untuk mengidentifikasi, menganalisis, dan mengevaluasi risiko terhadap aset informasi organisasi sehingga dapat ditentukan langkah-langkah pengendalian yang tepat. Bab ini akan mensimulasikan penilaian risiko secara kualitatif untuk beberapa aset informasi kritis di PT. Karya Sehat Abadi.

3.1. Metodologi Penilaian Risiko

Penilaian risiko dilakukan dengan pendekatan kualitatif berdasarkan matriks probabilitas dan dampak. Skala yang digunakan adalah:

Tabel 3.1. Skala Penilaian Dampak dan Kemungkinan

Level	Dampak (Tingkat Keparahan Konsekuensi)	Kemungkinan (Tingkat Probabilitas Terjadinya)
3 (Tinggi)	Parah: Mengganggu operasional utama, menyebabkan kerugian finansial besar (>1M), melanggar UU, merusak reputasi secara signifikan, membahayakan keselamatan pasien.	Tinggi: Sangat mungkin terjadi dalam setahun (>1 kali).
2 (Sedang)	Signifikan: Mengganggu operasional divisi, kerugian finansial menengah (100jt-1M), keluhan banyak pasien, dampak reputasi terbatas.	Sedang: Mungkin terjadi dalam setahun (sekali).
1 (Rendah)	Minor: Gangguan minimal, kerugian finansial kecil (<100jt), keluhan terbatas, dapat dipulihkan dengan cepat.	Rendah: Kecil kemungkinannya terjadi dalam setahun (<1 kali).

Level Risiko dihitung dengan rumus: **Dampak × Kemungkinan**.

Kriteria Level Risiko:

- **Risiko Tinggi (Merah):** Nilai 6 - 9. Memerlukan tindakan segera dan pengendalian wajib.
- **Risiko Sedang (Kuning):** Nilai 3 - 4. Memerlukan rencana manajemen risiko dan pemantauan.
- **Risiko Rendah (Hijau):** Nilai 1 - 2. Dapat diterima atau dikelola dengan prosedur existing.

3.2. Hasil Identifikasi dan Analisis Risiko

Berikut adalah hasil penilaian risiko untuk beberapa aset informasi utama PT. Karya Sehat Abadi.

Tabel 3.2. Matriks Penilaian Risiko Keamanan Informasi

Aset	Ancaman	Kerentanan	Dampak	Kemungkinan	Level Risiko	Tindakan Mitigasi (Rencana Awal)
Database Rekam Medis Elektronik	Ransomware Attack: Penyerang mengenkripsi database dan meminta tebusan.	- Sistem operasi/server yang tidak di-patch. - Kurangnya segmentasi jaringan. - Tidak ada backup yang terisolasi dan teruji.	3 (Parah)	2 (Sedang)	6 (Tinggi)	- Menerapkan kebijakan patch management yang ketat. - Melakukan segmentasi jaringan memisahkan jaringan HIS. - Menerapkan skema backup 3-2-1 (3 salinan, 2 media, 1 offsite) dan melakukan restore test rutin.
Data Rekam Medis Elektronik	Insider Threat: Karyawan yang berwenang menyalahgunakan akses (melihat data selebritas, menjual data).	- Tidak adanya kontrol akses berbasis peran (Role-Based Access Control/RBAC) yang ketat. - Tidak ada logging dan monitoring yang memadai. - Kurangnya pelatihan kesadaran keamanan.	3 (Parah)	2 (Sedang)	6 (Tinggi)	- Menerapkan RBAC dengan prinsip least privilege. - Menerapkan sistem SIEM untuk memantau dan menganalisis log akses. - Menyelenggarakan pelatihan kesadaran keamanan dan menandatangani perjanjian kerahasiaan.
Server Aplikasi HIS	DDoS Attack: Serangan membanjiri server	- Konfigurasi firewall yang tidak optimal. - Tidak adanya layanan	3 (Parah)	2 (Sedang)	6 (Tinggi)	- Melakukan hardening pada konfigurasi firewall dan server. - Berlangganan

Aset	Ancaman	Kerentanan	Dampak	Kemungkinan	Level Risiko	Tindakan Mitigasi (Rencana Awal)
	dengan lalu lintas, membuat layanan down.	mitigasi DDoS. - Rencana penanggulangan bencana (DRP) yang tidak memadai.				layanan mitigasi DDoS dari ISP atau cloud. - Mengembangkan dan menguji Disaster Recovery Plan (DRP) secara berkala.
Kredensial Login Pengguna	Phishing Attack: Karyawan tertipu untuk memberikan username dan password.	- Tidak adanya autentikasi multi-faktor (MFA). - Kurangnya pelatihan anti-phishing. - Kebijakan kata sandi yang lemah.	2 (Signifikan)	3 (Tinggi)	6 (Tinggi)	- Mewajibkan MFA untuk semua akses ke sistem HIS, terutama dari luar jaringan. - Melakukan simulasi phishing berkala kepada karyawan. - Menerapkan kebijakan kata sandi yang kuat dan kompleks.
Laptop/Desktop Karyawan	Malware Infection: Terinfeksi malware dari USB drive atau email yang mengganggu kerja.	- Tidak ada antivirus yang terpusat dan terupdate. - Hak akses pengguna yang terlalu tinggi (bisa install software). - Tidak ada kebijakan penggunaan media removable.	2 (Signifikan)	3 (Tinggi)	6 (Tinggi)	- Menerapkan Endpoint Protection Platform (EPP) terpusat. - Membatasi hak akses pengguna (user privilege) berdasarkan kebutuhan. - Menerapkan kebijakan dan kontrol teknis untuk memblokir atau memindai USB drive.

Aset	Ancaman	Kerentanan	Dampak	Kemungkinan	Level Risiko	Tindakan Mitigasi (Rencana Awal)
Perangkat Medis (CT-Scan)	Eksplorasi Kerentanan: Penyerang mengeksplorasi celah keamanan pada OS perangkat medis yang lama.	- Sistem operasi perangkat medis yang tidak boleh/tidak bisa di-patch karena alasan kompatibilitas. - Perangkat terhubung ke jaringan utama tanpa isolasi.	3 (Parah)	1 (Rendah)	3 (Sedang)	- Melakukan segmentasi jaringan khusus untuk perangkat medis (VLAN terpisah). - Menerapkan kontrol akses jaringan yang ketat ke segmen tersebut. - Meminta pengecualian resmi dari vendor dan mendokumentasikan risikonya.
Dokumen Kertas Rekam Medis Lama	Pencurian atau Kehilangan Fisik: Dokumen hilang atau diambil oleh pihak tidak berwenang.	- Penyimpanan fisik di ruang arsip yang tidak terkunci dengan baik. - Tidak ada kontrol akses logbook untuk ruang arsip. - Prosedur peminjaman yang tidak ketat.	3 (Parah)	1 (Rendah)	3 (Sedang)	- Mengunci ruang arsip dan membatasi akses hanya kepada personel yang berwenang. - Menerapkan sistem peminjaman dan pengembalian dokumen yang tercatat. - Mempercepat program digitalisasi dokumen kertas.

3.3. Kesimpulan Penilaian Risiko

Berdasarkan analisis di atas, PT. Karya Sehat Abadi memiliki beberapa **risiko tinggi** yang memerlukan penanganan segera. Risiko-risiko ini terutama berkisar pada ancaman siber terhadap sistem digital inti (HIS dan datanya) serta kerentanan yang disebabkan oleh faktor manusia. Hasil penilaian risiko ini akan menjadi masukan langsung untuk tahap berikutnya, dimana tujuan keamanan informasi dan rencana penanganan risiko (Statement of Applicability) akan ditetapkan. Tindakan mitigasi yang diusulkan akan dipertimbangkan untuk diadopsi sebagai kontrol keamanan informasi dalam skema ISO/IEC 27002.

BAB IV

PEMILIHAN DAN RANCANGAN KONTROL KEAMANAN INFORMASI

Tahap ini bertujuan untuk menentukan kontrol keamanan informasi yang paling sesuai guna menangani risiko-risiko yang telah diidentifikasi pada Bab III. Pemilihan kontrol mengacu pada **Annex A ISO/IEC 27001:2022** yang selaras dengan ISO/IEC 27002:2022. Kontrol dipilih berdasarkan tingkat risiko, efektivitas pengendalian, serta kesesuaian dengan kondisi operasional PT. Karya Sehat Abadi.

4.1. Daftar Kontrol Keamanan yang Dipilih

Berikut adalah minimal 10 kontrol keamanan informasi yang dipilih beserta alasan dan rencana penerapannya:

- 1. A.5.1 – Kebijakan Keamanan Informasi**
Alasan: Kurangnya kebijakan terdokumentasi menjadi kelemahan internal utama.
Penerapan: Menyusun dan mengesahkan kebijakan keamanan informasi yang berlaku untuk seluruh karyawan dan pihak ketiga.
- 2. A.5.7 – Threat Intelligence**
Alasan: Ancaman siber di sektor kesehatan sangat dinamis.
Penerapan: Divisi TI memantau informasi ancaman siber dari sumber tepercaya (CERT, BSSN, vendor keamanan).
- 3. A.6.1 – Screening (Penyaringan SDM)**
Alasan: Mengurangi risiko insider threat.
Penerapan: Proses rekrutmen mencakup verifikasi identitas dan latar belakang sesuai regulasi.
- 4. A.6.3 – Information Security Awareness, Education and Training**
Alasan: Budaya keamanan informasi masih lemah.
Penerapan: Pelatihan keamanan informasi dan simulasi phishing dilakukan minimal 1 kali per tahun.
- 5. A.8.2 – Privileged Access Rights**
Alasan: Penyalahgunaan hak akses berisiko tinggi pada data rekam medis.
Penerapan: Penerapan **Role-Based Access Control (RBAC)** dan prinsip *least privilege*.
- 6. A.8.5 – Secure Authentication**
Alasan: Risiko phishing dan pencurian kredensial.
Penerapan: Penerapan **Multi-Factor Authentication (MFA)** untuk sistem HIS dan akses jarak jauh.
- 7. A.8.13 – Information Backup**
Alasan: Ancaman ransomware terhadap ketersediaan data.
Penerapan: Skema backup **3-2-1** dan uji pemulihan (restore test) berkala.

8. **A.8.16 – Monitoring Activities**

Alasan: Kurangnya deteksi dini insiden keamanan.

Penerapan: Implementasi logging terpusat dan pemantauan akses sistem (SIEM sederhana).

9. **A.8.20 – Network Security**

Alasan: Kompleksitas jaringan dan perangkat medis terhubung.

Penerapan: Segmentasi jaringan (VLAN) antara HIS, jaringan kantor, dan perangkat medis.

10. **A.5.30 – ICT Readiness for Business Continuity**

Alasan: Gangguan sistem berdampak langsung pada layanan pasien.

Penerapan: Penyusunan dan pengujian **Disaster Recovery Plan (DRP)** dan **Business Continuity Plan (BCP)**.

BAB V

RANCANGAN DOKUMEN UTAMA SMKI

5.1. Kebijakan Keamanan Informasi (Information Security Policy)

Tujuan:

Menetapkan komitmen PT. Karya Sehat Abadi dalam melindungi kerahasiaan, integritas, dan ketersediaan informasi.

Pernyataan Kebijakan:

PT. Karya Sehat Abadi berkomitmen untuk menerapkan Sistem Manajemen Keamanan Informasi sesuai ISO/IEC 27001 guna melindungi seluruh aset informasi dari ancaman internal maupun eksternal, mematuhi peraturan perundang-undangan (termasuk UU PDP), serta mendukung kelangsungan layanan kesehatan.

Ruang Lingkup:

Seluruh unit kerja, karyawan, sistem informasi, dan pihak ketiga yang memiliki akses ke informasi rumah sakit.

5.2. Tujuan Keamanan Informasi (Information Security Objectives)

1. Menjamin kerahasiaan data rekam medis pasien.
2. Menjaga integritas data medis agar tidak terjadi perubahan tidak sah.
3. Menjamin ketersediaan sistem HIS minimal 99% uptime.
4. Mengurangi insiden keamanan informasi akibat faktor manusia.
5. Memastikan kepatuhan terhadap UU Perlindungan Data Pribadi.

Tujuan ini akan dievaluasi setiap tahun melalui audit internal SMKI.

5.3. Rencana Implementasi SMKI (Implementation Plan)

Tahap	Aktivitas	Penanggung Jawab	Waktu
Perencanaan	Pembentukan tim SMKI & penetapan kebijakan	Direksi & TI	Bulan 1

Implementasi	Penerapan kontrol teknis (MFA, backup, RBAC)	Divisi TI	Bulan 2–4
Awareness	Pelatihan & sosialisasi kebijakan	SDM & TI	Bulan 3
Evaluasi	Audit internal & penilaian efektivitas	Tim SMKI	Bulan 5
Perbaikan	Tindakan korektif & peningkatan	Manajemen	Bulan 6

BAB VI

KESIMPULAN DAN REKOMENDASI

6.1. Kesimpulan

Berdasarkan simulasi penerapan SMKI ISO/IEC 27001 pada PT. Karya Sehat Abadi, dapat disimpulkan bahwa organisasi memiliki risiko keamanan informasi yang signifikan, khususnya terkait perlindungan data rekam medis dan ketergantungan pada sistem HIS. Pemilihan kontrol dari Annex A ISO/IEC 27001:2022 memberikan kerangka pengendalian yang memadai untuk menurunkan tingkat risiko ke level yang dapat diterima.

6.2. Rekomendasi

1. Manajemen perlu menunjukkan komitmen berkelanjutan terhadap SMKI.
2. Organisasi disarankan melakukan audit internal SMKI secara rutin.
3. Peningkatan kompetensi SDM di bidang keamanan informasi harus menjadi prioritas.
4. Setelah implementasi stabil, PT. Karya Sehat Abadi dapat melanjutkan ke proses **sertifikasi ISO/IEC 27001** oleh lembaga sertifikasi terakreditasi.

Dengan penerapan SMKI yang konsisten dan berkelanjutan, PT. Karya Sehat Abadi akan mampu meningkatkan kepercayaan pasien, kepatuhan regulasi, dan ketahanan organisasi terhadap ancaman siber.

KESIMPULAN (BAB I – VI)

Berdasarkan analisis dan simulasi yang telah dilakukan pada Bab I hingga Bab III, dapat disimpulkan bahwa penerapan Sistem Manajemen Keamanan Informasi (SMKI) berbasis ISO/IEC 27001 merupakan sebuah keharusan strategis bagi PT. Karya Sehat Abadi untuk memastikan kelangsungan bisnis, kepatuhan regulasi, dan yang terpenting, menjaga kepercayaan pasien.

Pertama, dari Bab I: Pendahuluan, dipahami bahwa PT. Karya Sehat Abadi sebagai rumah sakit swasta dengan layanan paripurna sangat bergantung pada aset informasi yang kritis dan sensitif, terutama Data Rekam Medis Elektronik. Ruang lingkup penerapan SMKI yang menyeluruh di seluruh organisasi dinilai tepat mengingat data yang perlu dilindungi tersebar di hampir semua unit kerja dan proses bisnis inti. Kompleksitas infrastruktur TI dan integrasi perangkat medis semakin memperkuat kebutuhan akan sebuah kerangka kerja manajemen keamanan yang terstruktur.

Kedua, hasil Bab II: Analisis Konteks Organisasi mengungkapkan bahwa rumah sakit ini beroperasi dalam lingkungan yang penuh dengan tantangan. Secara internal, budaya keamanan yang lemah dan keterbatasan sumber daya menjadi titik lemah utama. Secara eksternal, tekanan dari ancaman siber yang semakin canggih (seperti ransomware) dan tuntutan regulasi UU PDP menciptakan lingkungan yang sangat berisiko. Berbagai pihak berkepentingan, terutama pasien, memiliki ekspektasi tinggi terhadap kerahasiaan dan ketersediaan data mereka, yang jika dilanggar akan berakibat fatal pada reputasi dan keberlangsungan operasional rumah sakit.

Ketiga, Bab III: Penilaian Risiko Keamanan Informasi berhasil mengidentifikasi dan memprioritaskan risiko-risiko kunci. Analisis kualitatif menunjukkan beberapa risiko tinggi (level 6) yang memerlukan penanganan segera, antara lain:

1. Serangan Ransomware yang dapat melumpuhkan operasional.
2. Ancaman dari dalam (Insider Threat) yang dapat menyalahgunakan akses data.
3. Serangan DDoS yang dapat mengganggu ketersediaan layanan.
4. Serangan Phishing yang menargetkan kredensial karyawan.

Risiko-risiko ini sebagian besar bersumber dari kombinasi kerentanan teknis (seperti sistem yang tidak ter-patch dan kurangnya segmentasi jaringan) dan kerentanan manusia (kurangnya kesadaran dan pelatihan). Tindakan mitigasi yang diusulkan, seperti penerapan *Multi-Factor Authentication (MFA)*, *segmentasi jaringan*, *backup yang robust*, dan *pelatihan kesadaran keamanan*, memberikan peta jalan awal yang jelas untuk memperkuat postur keamanan informasi rumah sakit.

Secara keseluruhan, tiga bab awal ini telah membangun fondasi yang kuat untuk penerapan SMKI lebih lanjut. Telah jelas konteks organisasi, pihak-pihak yang berkepentingan, serta risiko-risiko utama yang dihadapi. Langkah selanjutnya adalah menggunakan temuan ini untuk menetapkan kebijakan keamanan informasi, menetapkan tujuan keamanan, dan memilih kontrol yang tepat (dokumentasikan dalam *Statement of Applicability*) sebagai bagian dari proses perencanaan dalam siklus PDCA (Plan-Do-Check-Act) ISO/IEC 27001.

Pada Tahap 4 (Pemilihan dan Rancangan Kontrol), organisasi telah berhasil memilih kontrol keamanan yang relevan dari Annex A ISO/IEC 27001:2022 berdasarkan hasil penilaian risiko sebelumnya. Pemilihan minimal sepuluh kontrol, seperti kebijakan keamanan informasi, pengelolaan

hak akses, autentikasi aman, backup data, keamanan jaringan, serta kesiapan teknologi untuk keberlangsungan bisnis, menunjukkan bahwa risiko-risiko utama—khususnya terkait data rekam medis, ancaman siber, dan faktor manusia—telah ditangani secara sistematis. Kontrol yang dipilih juga mempertimbangkan kondisi operasional rumah sakit sehingga realistis untuk diterapkan.

Selanjutnya, pada Tahap 5 (Rancangan Dokumen Utama SMKTI), organisasi telah menyusun dokumen inti SMKTI yang meliputi Kebijakan Keamanan Informasi, Tujuan Keamanan Informasi, dan Rencana Implementasi SMKTI. Dokumen-dokumen ini berfungsi sebagai landasan formal dalam penerapan SMKTI serta menjadi pedoman bagi seluruh karyawan dan pihak terkait dalam menjaga kerahasiaan, integritas, dan ketersediaan informasi. Dengan adanya rencana implementasi yang jelas, proses penerapan SMKTI dapat dilakukan secara bertahap, terukur, dan terkontrol.

Pada Tahap 6 (Kesimpulan dan Rekomendasi), dapat disimpulkan bahwa penerapan SMKTI di PT. Karya Sehat Abadi memiliki potensi besar untuk meningkatkan perlindungan aset informasi, kepatuhan terhadap regulasi perlindungan data pribadi, serta kepercayaan pasien dan pemangku kepentingan. Rekomendasi tindak lanjut berupa komitmen manajemen, audit internal berkala, peningkatan kesadaran keamanan informasi, dan persiapan sertifikasi ISO/IEC 27001 menjadi langkah strategis agar SMKTI dapat berjalan secara berkelanjutan dan efektif.

Secara keseluruhan, Tahap 4 hingga Tahap 6 melengkapi fondasi penerapan SMKTI yang telah dibangun pada tahap sebelumnya dan menunjukkan bahwa PT. Karya Sehat Abadi berada pada jalur yang tepat untuk menuju implementasi penuh dan sertifikasi ISO/IEC 27001.

DAFTAR PUSTAKA

1. **International Organization for Standardization (ISO) & International Electrotechnical Commission (IEC).** (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Geneva, Switzerland: ISO.
2. **International Organization for Standardization (ISO) & International Electrotechnical Commission (IEC).** (2022). *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls*. Geneva, Switzerland: ISO.
3. **Republic of Indonesia.** (2022). *Undang-Undang Nomor 27 Tahun 2022 tentang Perlindungan Data Pribadi*. Lembaran Negara Republik Indonesia Tahun 2022 Nomor 27. Jakarta.
4. **Calder, A., & Watkins, S. G.** (2020). *IT Governance: An International Guide to Data Security and ISO27001/ISO27002* (7th ed.). Kogan Page.
5. **Humphreys, E.** (2018). *Implementing the ISO/IEC 27001:2022 Information Security Management System Standard* (4th ed.). IT Governance Publishing.
6. **Peltier, T. R.** (2016). *Information Security Policies, Procedures, and Standards: Guidelines for Effective Information Security Management*. CRC Press.
7. **SANS Institute.** (2023). *The Top Cyber Security Risks in the Healthcare Sector*. Diakses pada 15 Oktober 2024, dari <https://www.sans.org/white-papers/top-cyber-risks-healthcare/>
8. **Health Information Trust Alliance (HITRUST).** (2023). *Understanding the Intersection of HIPAA, GDPR, and Other Privacy Regulations with HITRUST*. Diakses pada 16 Oktober 2024, dari <https://hitrustalliance.net/>
9. **Kementerian Kesehatan Republik Indonesia.** (2018). *Peraturan Menteri Kesehatan Republik Indonesia Nomor 24 Tahun 2022 tentang Rekam Medis*. Jakarta.